

PENETRATION TESTING REPORT

Mediroza General Hospital *Black -Box Security Assessment*

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Black- Box Penetration Test
Duration	5 days
Tester	Pavithra p
Program	Networkwalks Internship — Batch B083 Week 4
Classification	CONFIDENTIAL

This assessment is presented for authorized educational security testing only.

1. Executive Summary

A five-days black-box penetration test was conducted against the external web infrastructure of Mediroza General Hospital. The assessment focused on identifying weaknesses in the patient portal, authentication controls, protected patient documents, exposed server directories, and publicly accessible database backups.

The assessment identified a chained attack path beginning with information disclosure and authentication weaknesses, followed by SQL injection, access to protected patient reports, weak PDF password protection, metadata disclosure, and exposure of a database backup. The exposed backup contained confidential staff salary information and shareholder ownership data.

Overall Risk Posture: CRITICAL

The overall risk is assessed as CRITICAL because multiple weaknesses can be combined to reach sensitive medical, employee, and organizational information.

Key findings identified during the engagement:

- Username enumeration on the patient login page — Medium
- SQL Injection authentication bypass — Critical
- Unauthorized access to encrypted patient PDFs after login bypass — High
- Weak PDF passwords that are recoverable using a wordlist — High
- Sensitive metadata exposed in a patient PDF — Medium
- Public directory listing exposing an old database backup — Critical
- Plain-text staff salary and shareholder information in the exposed database backup — Critical

Immediate remediation should prioritize the SQL injection flaw, removal of public database backups, disabling directory listing, and strengthening access controls and encryption for patient documents.

2. Scope and Methodology

2.1 Scope

Target	https://medirozahospital.co
Testing Type	Black- Box Penetration Test
Duration	5-days
Assessment focus	Patient portal, authentication, PDF protection, metadata, exposed directories and database backup
Authorization	Testing performed in the authorized educational environment

2.2 Methodology

The assessment followed a structured penetration-testing workflow:

- Reconnaissance — review of robots.txt and identification of accessible application areas.
- Vulnerability identification — testing authentication behaviour and input handling.
- Exploitation — validation of the SQL injection issue and authorized access to the portal.
- Post-exploitation analysis — examination of downloaded PDF files, encryption, metadata and exposed server resources.
- Data exposure assessment — review of the publicly accessible database backup and the sensitive records it contained.
- Documentation — recording evidence, risk ratings and remediation recommendations.

2.3 Tools Used

Tools and resources used in the supplied Networkwalks solution include browser tools, curl, manual SQL injection testing, the Networkwalks Hash Calculator, Networkwalks Password Cracker, qpdf, exiftool, wget, grep and authorized wordlists.

3. Findings and Proof of Exploitation

The findings below follow the attack-chain order presented in the supplied Networkwalks solution. Each finding includes its severity, description, proof and an area for your own screenshot.

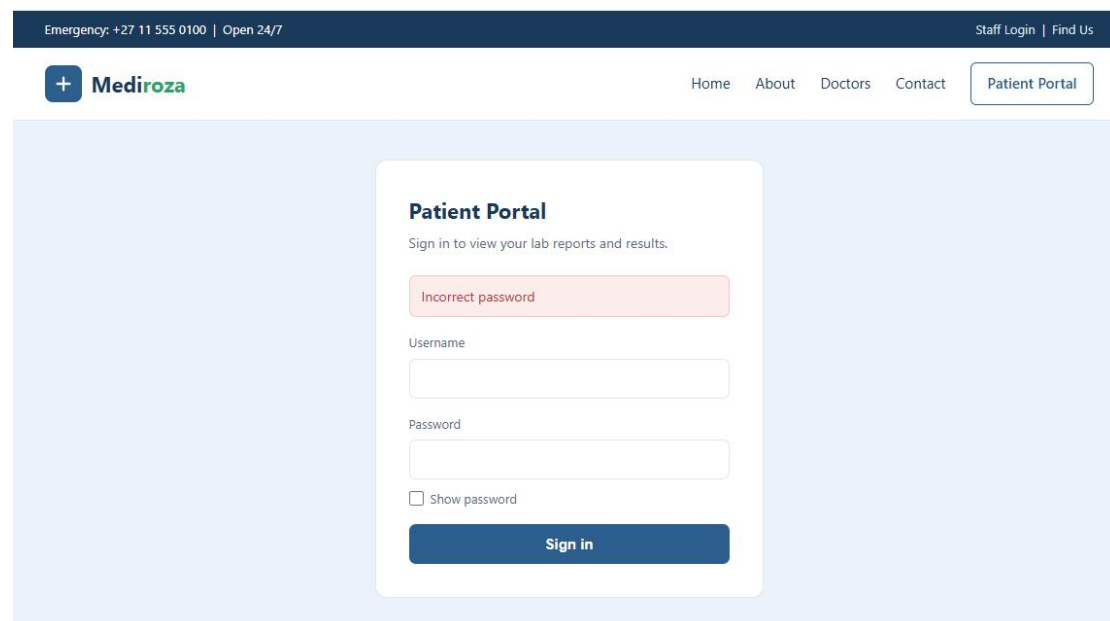
Finding 1 — Username Enumeration

Severity: MEDIUM

Vulnerability Synopsis: The patient login page returned different responses for a non-existent username and an existing username. This behaviour allows an attacker to determine whether an account exists.

Proof / Evidence: A test username returned “Username not found”, while the username admin returned “Incorrect password”. The difference confirms that the application discloses account existence.

Affected Location: Patient login page /patient/login.php



The screenshot displays the Mediroza Patient Portal login interface. At the top, a dark blue header contains the emergency contact number '+27 11 555 0100 | Open 24/7' on the left and 'Staff Login | Find Us' on the right. Below the header, the Mediroza logo is on the left, and navigation links for 'Home', 'About', 'Doctors', 'Contact', and 'Patient Portal' are on the right. The main content area features a white login box with the title 'Patient Portal' and the instruction 'Sign in to view your lab reports and results.' A red error message 'Incorrect password' is displayed above the input fields. The form includes fields for 'Username' and 'Password', a 'Show password' checkbox, and a blue 'Sign in' button.

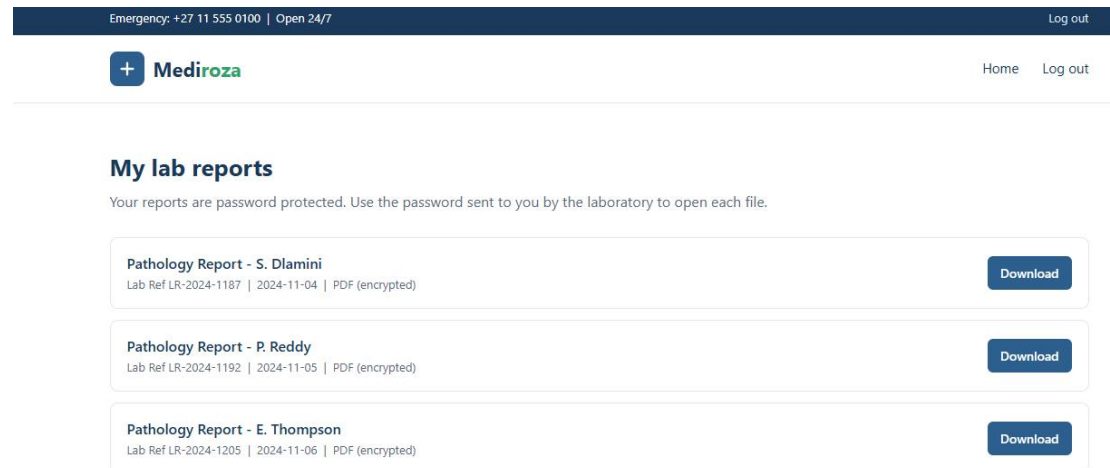
Finding 2 — SQL Injection Authentication Bypass

Severity: CRITICAL

Vulnerability Synopsis: The login parameter was vulnerable to SQL injection. A quote caused a database syntax error, confirming that user input was being inserted into a SQL query without adequate Parameterization.

Proof / Evidence : The authorized test demonstrated that the authentication control could be bypassed, resulting in access to the portal and its three listed pathology reports.

Affected Location: Patient login page /patient/login.php



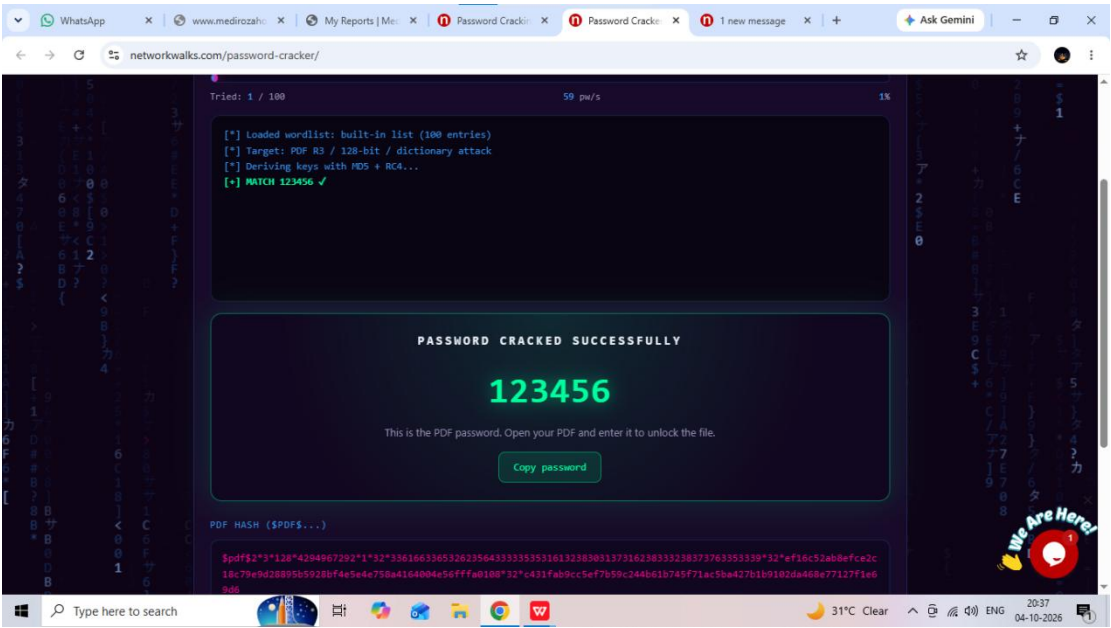
Finding 3— Weak PDF Password Protection

Severity: HIGH

Vulnerability Synopsis: The downloaded PDF reports used password-based encryption with weak passwords that were recoverable using authorized wordlists.

Proof / Evidence: Reports 1 and 2 were recovered using the supplied common-password list. Report 3 required the larger JTR wordlist supplied for the exercise.

Affected Location: patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf



Finding 4 — Sensitive PDF Metadata Exposure
Severity: MEDIUM

Vulnerability Synopsis: After an authorized PDF was unlocked, metadata contained information that revealed an internal operational clue.
Proof / Evidence: The metadata included an author value and a comment referring to a database backup being moved to the /old directory. This information helped connect the document to another exposed resource.

Affected Location: patient_report_3.pdf metadata

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PDF to V

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Emily Thompson

Patient ID:

MG-P-10258

Date of Birth:

1978-09-03

Gender:

Female

Report Date:

2024-11-06

Referring Dr:

Dr. Ahmed Kara

Specimen:

Serum

Lab Ref No:

LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

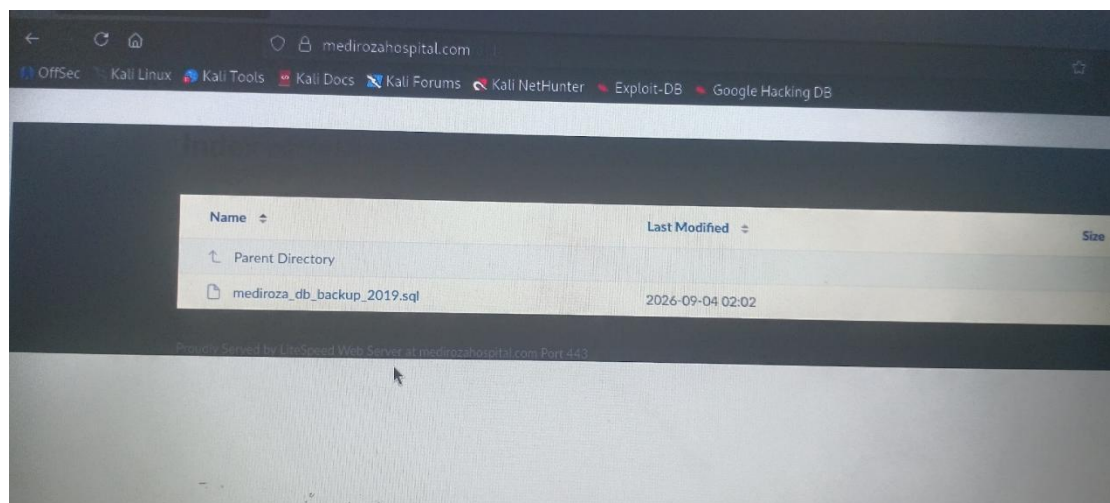
Findings 5 — Public Directory Listing and Database Backup Exposure

Severity: CRITICAL

Vulnerability Synopsis: The /old/ directory had directory listing enabled and exposed a database backup file.

Proof / Evidence: The exposed file was mediroza_db_backup_2019.sql. The backup could be downloaded and reviewed as plain SQL text.

Affected Location: <https://medirozahospital.com/old/>



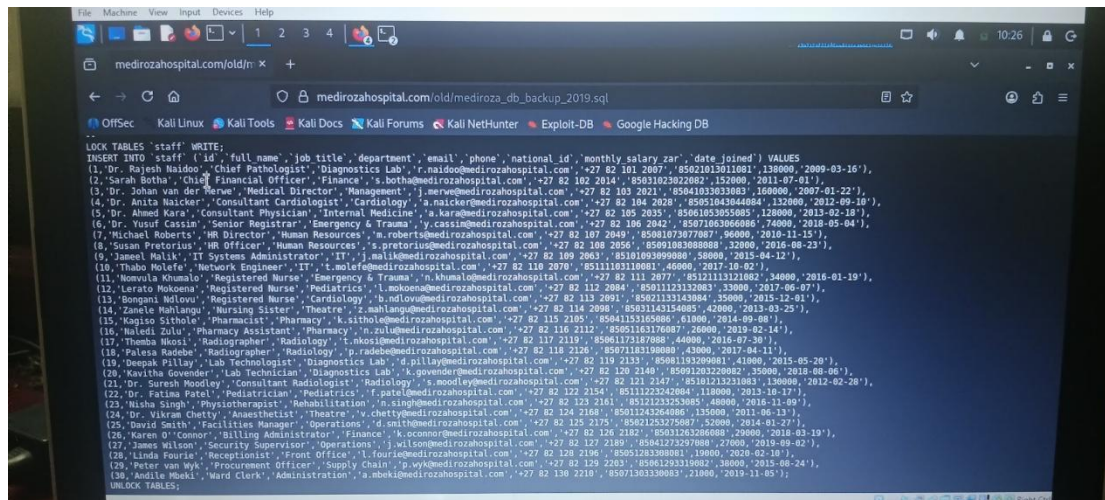
Finding 6— Sensitive Staff and Shareholder Data Exposure

Severity: CRITICAL

Vulnerability Synopsis: The exposed SQL backup contained staff records including job titles and salaries, as well as shareholder ownership percentages and share classes.

Proof / Evidence: The assessment confirmed that confidential organizational and financial information was present in the publicly accessible backup.

Affected Location: mediroza_db_backup_2019.sql



3.8 Exposed Data — Sample Evidence

The supplied assessment records that the exposed staff table contained approximately 30 employee records with monthly salaries in ZAR, while the shareholders table contained ownership stakes and share classes.

Employee /Shareholders	Title	Salary
Dr. Johan van der Merwe	Medical Director	R 160,000
Sarah Botha	Chief Financial Officer	R 152,000
Dr. Rajesh Naidoo	Chief Pathologist	R 138,000
Dr. Vikram Chetty	Anaesthetist	R 135,000
Linda Fourie	Receptionist	R 19,000
Dr. Rajesh Naidoo	Share ownership	18.0% Ordinary
Cedar Health Holdings	Share ownership	15.0% Ordinary
Dr. Johan van der Merwe	Share ownership	12.0% Ordinary
Dr. Vikram Chetty	Share ownership	4.0% Ordinary

4. Risk Rating

Vulnerability	Impact	Likelihood	Severity
SQL Injection	Full unauthorized access	High (trivial)	CRITICAL
Data Exposure (DB Dump)	Financial & PII leak High	High ((public)	CRITICAL
Weak PDF Encryption	Medical record exposure	High (wordlist)	HIGH

Overall Risk: CRITICAL

The combined findings create a serious breach path because an authentication weakness can lead to access to medical reports, while a separate public backup exposure provides direct access to sensitive organizational data.

5. Recommendations and Remediation

1. Fix SQL Injection

Replace dynamically constructed SQL statements with parameterized queries or prepared statements. Validate and safely handle all user-controlled input.

Priority: Immediate

2. Prevent Username Enumeration

Return the same generic authentication message for invalid usernames and incorrect passwords. Avoid revealing whether an account exists.

Priority: High

3. Strengthen Patient Document Access

Store patient PDFs outside the public web root or place them behind robust authorization checks. Ensure that direct file URLs cannot bypass application access controls.

Priority: Immediate

4. Strengthen PDF Password Controls

Use strong, unique, randomly generated passwords for protected patient documents and avoid predictable or common passwords.

Priority: High

5. Remove Sensitive PDF Metadata

Review documents before publication and remove unnecessary metadata that may disclose internal usernames, paths, comments or operational information.

Priority: Medium

6. Secure Database Backups

Move database backups outside the public web root and disable directory listing. Never keep old SQL, LOG, BAK or similar sensitive files in publicly accessible folders.

Priority: Immediate

7. Audit Legacy Files

Perform a complete review of the web server for forgotten backup files and legacy directories. Remove files that are no longer required and apply appropriate permissions to retained backups.

Priority: High

8. Continuous Security Testing

Repeat vulnerability assessments after remediation and include authentication, file exposure, backup security and sensitive-data handling in future security reviews.

Priority: Medium

6. Conclusion

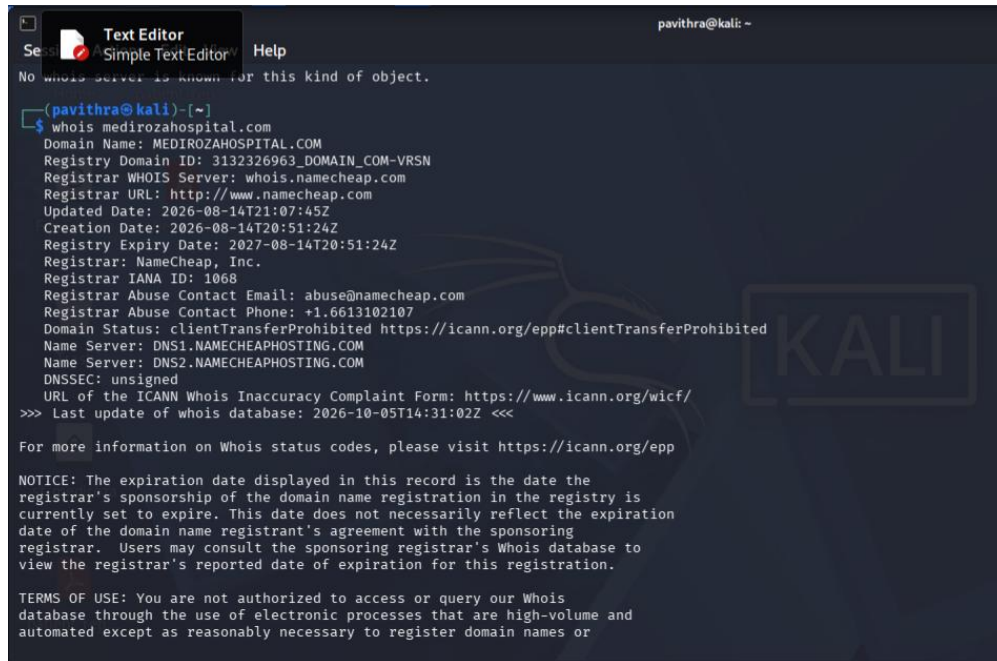
The Mediroza General Hospital black-box assessment identified multiple security weaknesses across the authentication, patient-document, metadata and backup-storage layers. The most significant issues were the SQL injection authentication bypass and the public exposure of the database backup. Together, these weaknesses could result in unauthorized disclosure of medical, employee and organizational information.

The findings demonstrate the importance of secure input handling, strong authentication behaviour, proper document protection, metadata hygiene, and secure management of database backups. Remediation should begin with the critical findings, followed by validation testing to confirm that the vulnerabilities have been fully resolved.

Appendix A — Evidence / Screenshot Placeholders

Insert your own screenshots below. Keep the screenshot number consistent with your practical work and add a short caption explaining what the screenshot proves

EVIDENCE 1.RECONNAISSANCE



```
Text Editor pavithra@kali: -
Simple Text EditorV Help
No whois server is known for this kind of object.

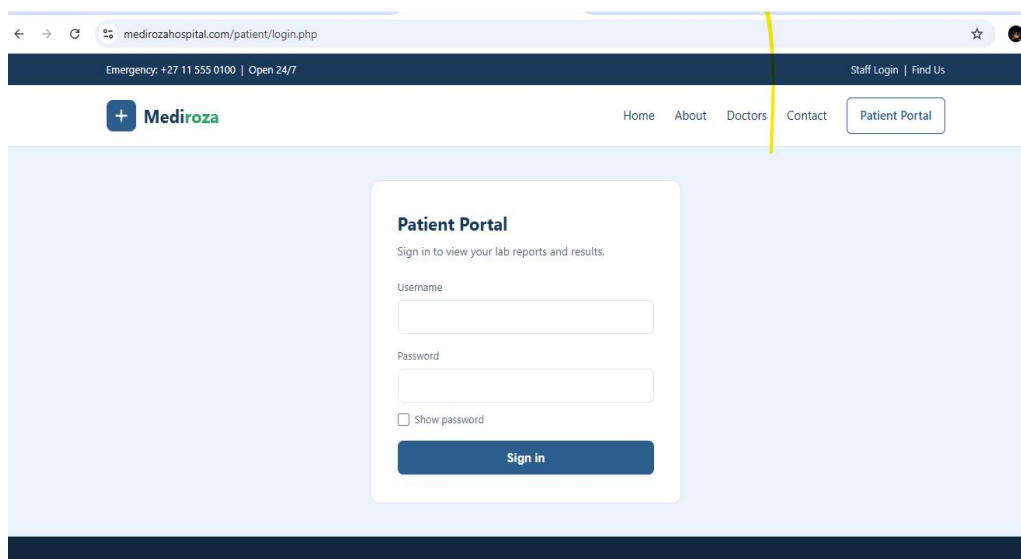
(pavithra@kali)-[~]
$ whois medirozahospital.com
Domain Name: MEDIROZAHOSPITAL.COM
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2026-08-14T21:07:45Z
Creation Date: 2026-08-14T20:51:24Z
Registry Expiry Date: 2027-08-14T20:51:24Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: DNS1.NAMECHEAPHOSTING.COM
Name Server: DNS2.NAMECHEAPHOSTING.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-10-05T14:31:02Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

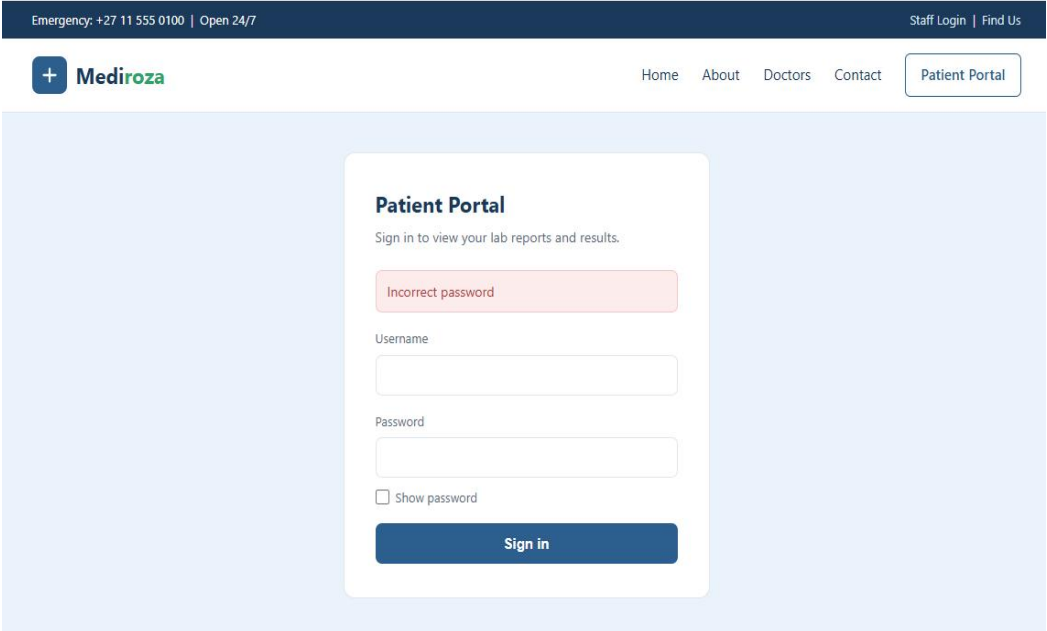
NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
```

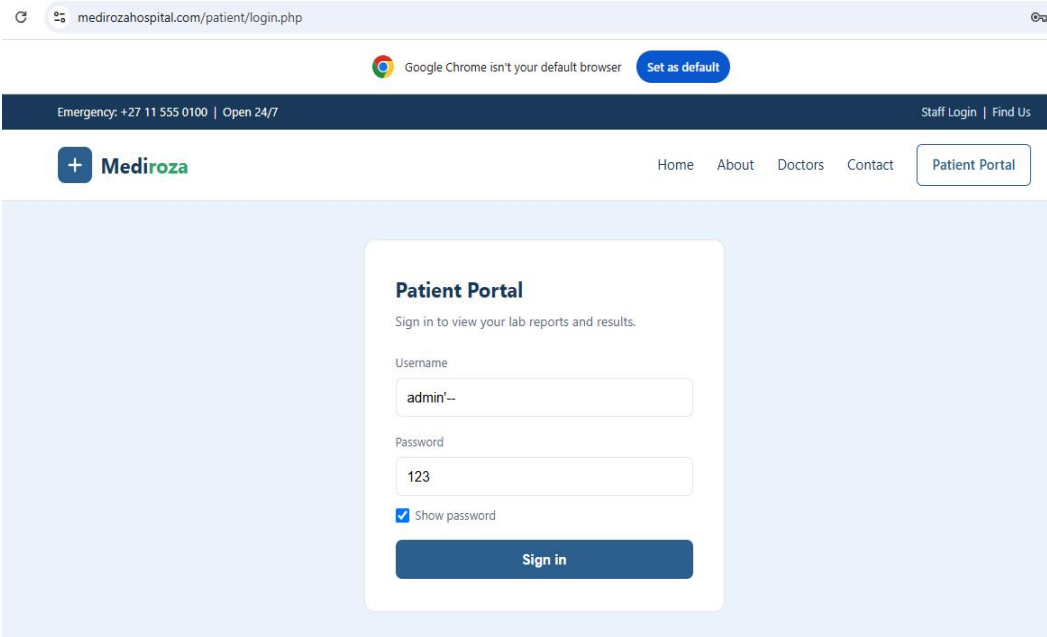
EVIDENCE 2.PATIENT LOGIN



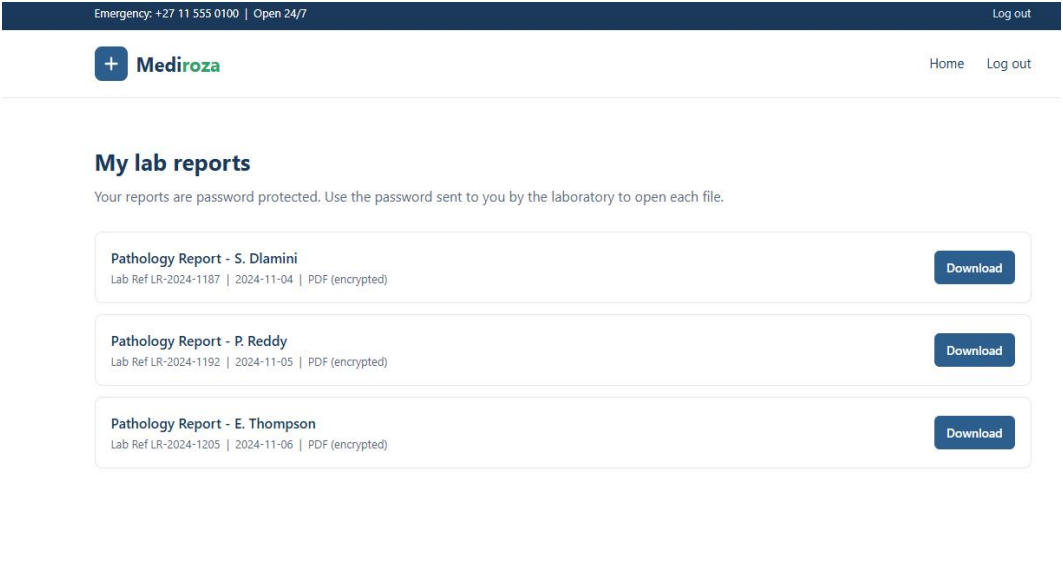
EVIDENCE 3.Username enumeration response



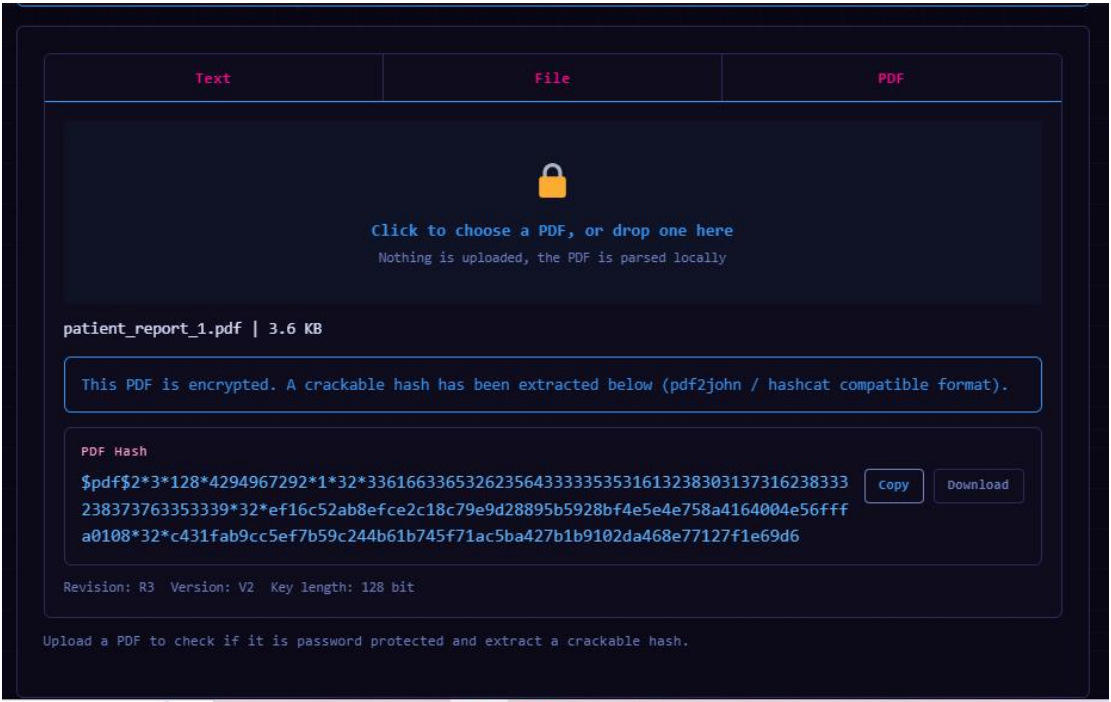
Evidence 4: Authorized login-bypass result



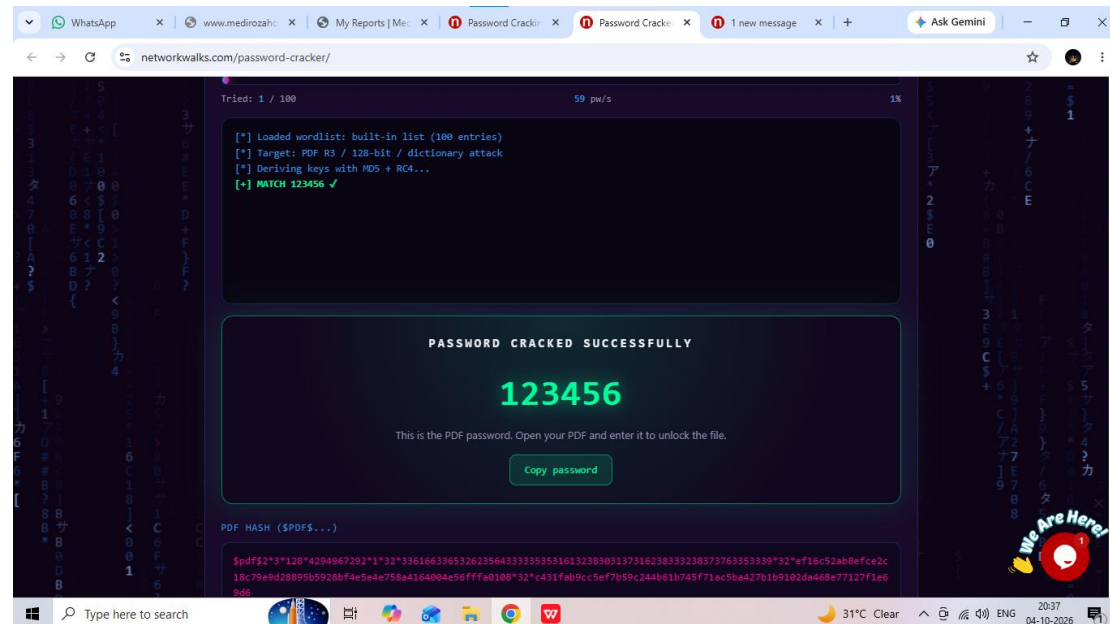
Evidence 5: Three patient reports listed in the portal



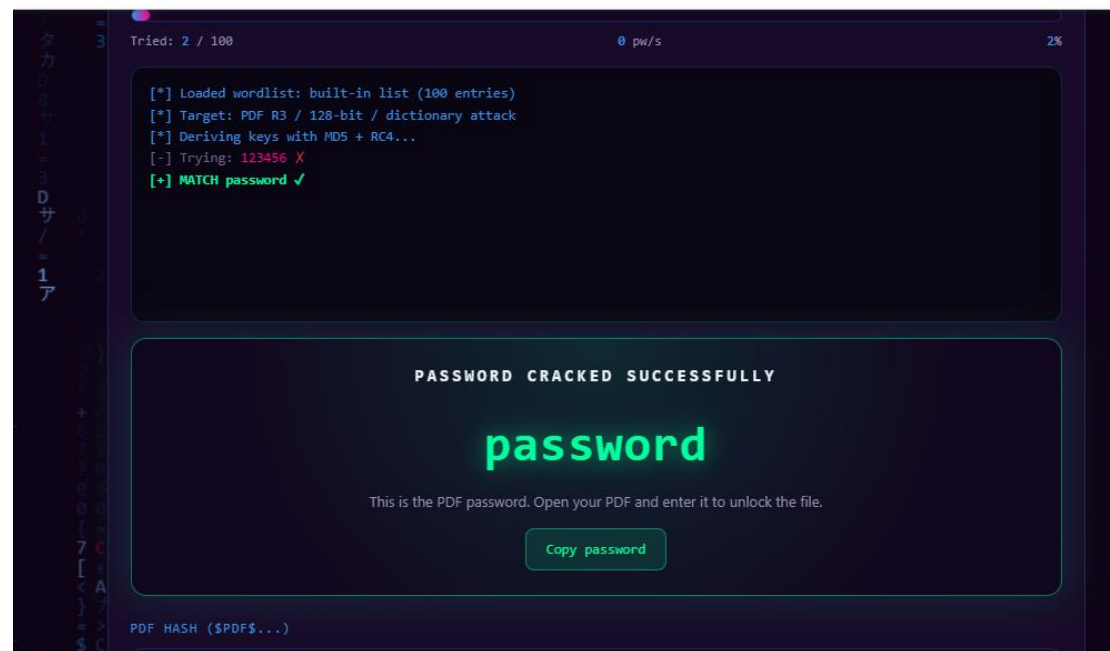
Evidence 6: PDF hash extraction



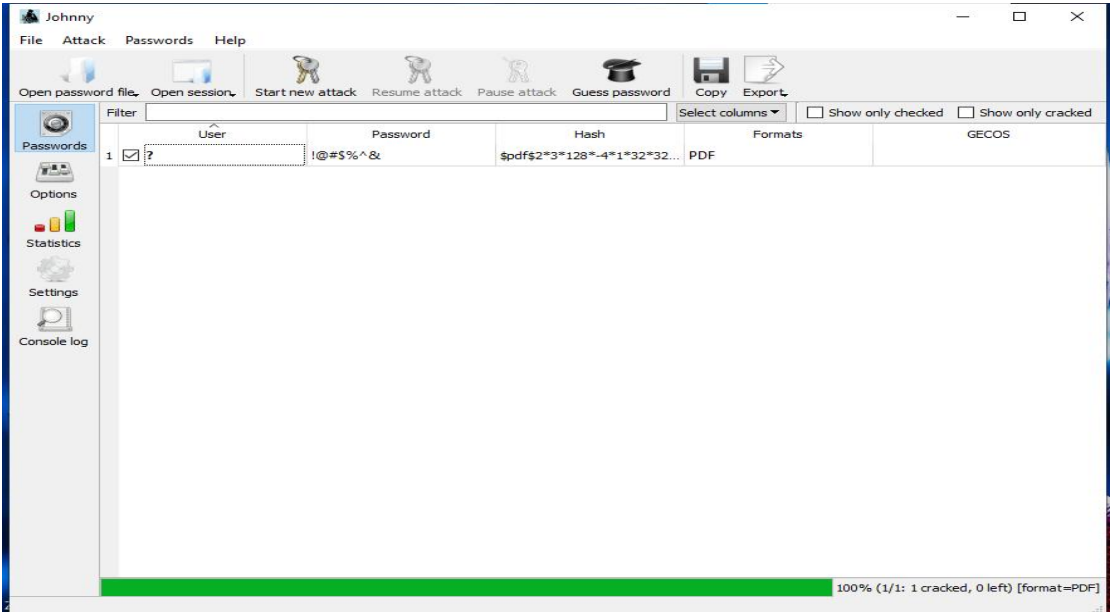
Evidence 7: Password-cracking result for report 1



Evidence 8: Password-cracking result for report 2



Evidence 9: Password-cracking result for report 3 using the larger wordlist



Evidence 10: Unlocked PDF / qpdf result

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Emily Thompson

Report Date:

2024-11-06

Patient ID:

MG-P-10258

Referring Dr:

Dr. Ahmed Kara

Date of Birth:

1978-09-03

Specimen:

Serum

Gender:

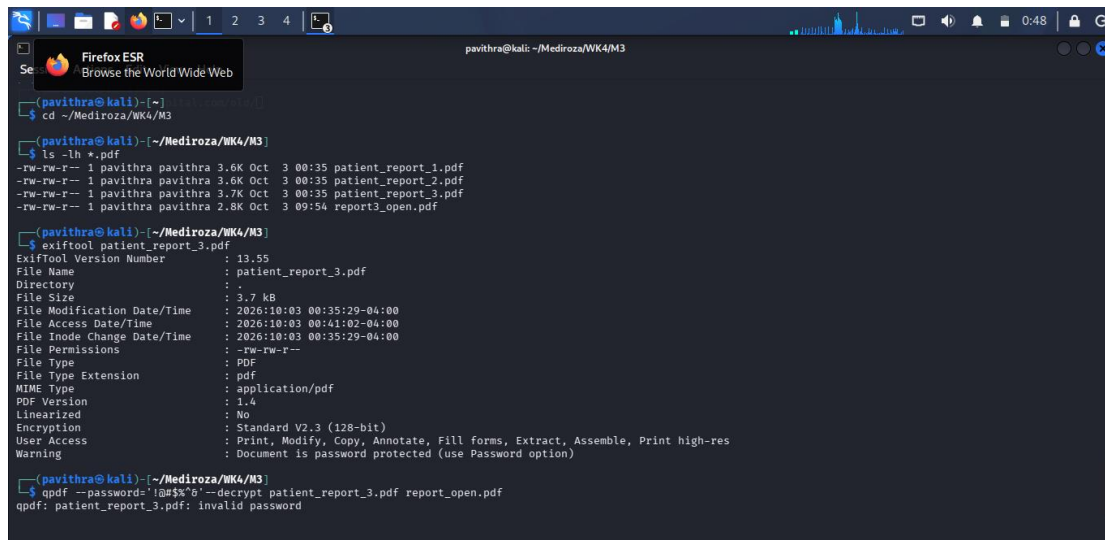
Female

Lab Ref No:

LR-2024-1205

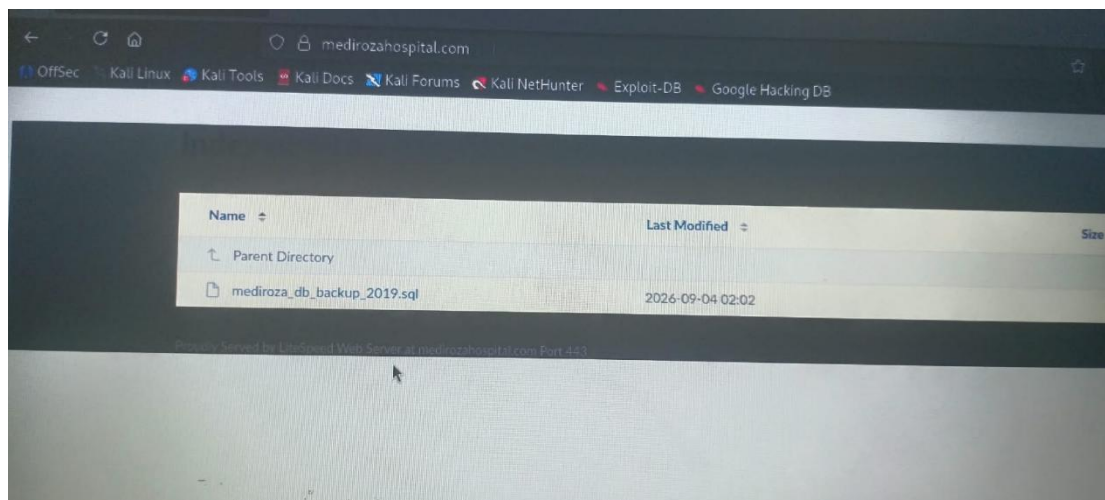
TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Evidence 11: exiftool metadata output

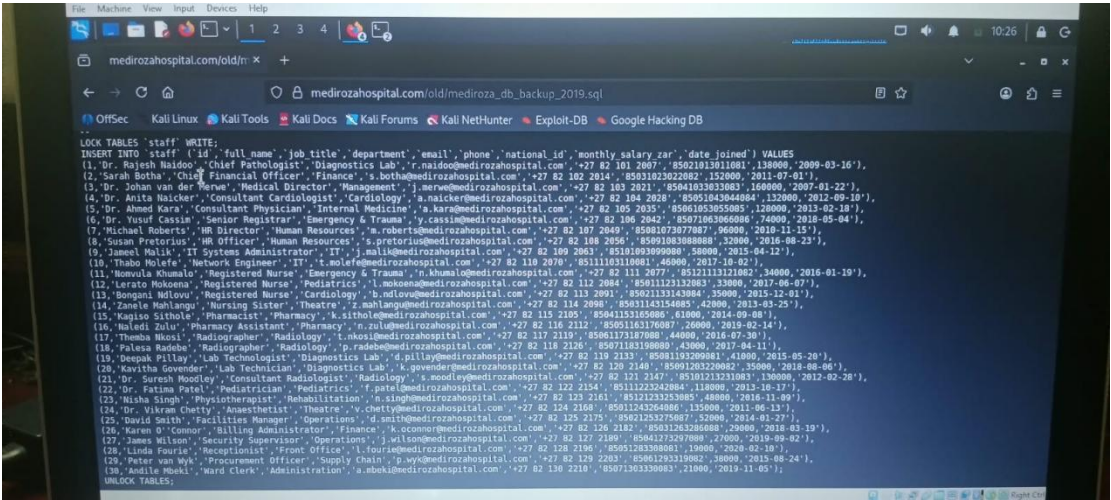


```
(pavithra@kali)~$ cd ~/Mediroza/WK4/M3
(pavithra@kali)~/Mediroza/WK4/M3$ ls -lh *.pdf
-rw-rw-r-- 1 pavithra pavithra 3.6K Oct  3 00:35 patient_report_1.pdf
-rw-rw-r-- 1 pavithra pavithra 3.6K Oct  3 00:35 patient_report_2.pdf
-rw-rw-r-- 1 pavithra pavithra 3.7K Oct  3 00:35 patient_report_3.pdf
-rw-rw-r-- 1 pavithra pavithra 2.8K Oct  3 09:54 report3_open.pdf
(pavithra@kali)~/Mediroza/WK4/M3$ exiftool patient_report_3.pdf
ExifTool Version Number      : 13.55
File Name                    : patient_report_3.pdf
Directory                    : .
File Size                    : 3.7 KB
File Modification Date/Time   : 2026:10:03 00:35:29-04:00
File Access Date/Time        : 2026:10:03 00:41:02-04:00
File Inode Change Date/Time   : 2026:10:03 00:35:29-04:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Encryption                   : Standard V2.3 (128-bit)
User Access                  : Print, Modify, Copy, Annotate, Fill forms, Extract, Assemble, Print high-res
Warning                      : Document is password protected (use Password option)
(pavithra@kali)~/Mediroza/WK4/M3$ qpdf --password='!@#$%^&'--decrypt patient_report_3.pdf report_open.pdf
qpdf: patient_report_3.pdf: invalid password
```

Evidence 12: Directory listing of /old/



Evidence 13: SQL backup download



Evidence 14: Staff table / salary evidence

No.	Name	Job Title	Department	Monthly Salary (ZAR)	
1	Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	R138,000	
2	Sarah Botha	Chief Financial Officer	Finance	R152,000	
3	Dr. Johan van der Merwe	Medical Director	Management	R160,000	
4	Dr. Anita Naicker	Consultant Cardiologist	Cardiology	R132,000	
5	Dr. Ahmed Kara	Consultant Physician	Internal Medicine	R128,000	
6	Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	R74,000	
7	Michael Roberts	HR Director	Human Resources	R96,000	
8	Susan Pretorius	HR Officer	Human Resources	R32,000	
9	Jameel Malik	IT System Administrator	IT	R58,000	

Mediroza penetration test report-pavithra

10	Thabo Molefe	Network Engineer	IT	R46,000
11	Nomvula Khumalo	Registered Nurse	Emergency & Trauma	R34,000
12	Lerato Mokoena	Registered Nurse	Pediatrics	R33,000
13	Bongani Ndlovu	Registered Nurse	Cardiology	R35,000
14	Zanele Mahlangu	Nursing Sister	Theatre	R42,000
15	Kagiso Sithole	Pharmacist	Pharmacy	R61,000
16	Naledi Zulu	Pharmacy Assistant	Pharmacy	R26,000
17	Themba Nkosi	Radiographer	Radiology	R44,000
18	Palesa Radebe	Radiographer	Radiology	R43,000
19	Deepak Pillay	Lab Technician	Diagnostics Lab	R41,000
20	Kavitha Govender	Lab Technician	Diagnostics Lab	R35,000
21	Dr. Suresh Moodley	Consultant Radiologist	Radiology	R130,000
22	Dr. Fatima Patel	Pediatrician	Pediatrics	R118,000
23	Nisha Singh	Physiotherapist	Rehabilitation	R48,000
24	Dr. Vikram Chetty	Anaesthetist	Theatre	R135,000
25	David Smith	Facilities Manager	Operations	R52,000
26	Karen O'Connor	Billing Administrator	Finance	R29,000
27	James Wilson	Security Supervisor	Operations	R27,000
28	Linda Fourie	Receptionist	Front Office	R19,000
29	Peter van Wyk	Procurement Officer	Supply Chain	R38,000
30	Andile Mbeki	Ward Clerk	Administration	R21,000

Evidence 16: Shareholders table evidence

#	Shareholder Name	Share Percentage	Share Clas	 Free offer
1	Dr. Rajesh Naidoo	18.0%	Ordinary	
2	Cedar Health Holdings (Pty) Ltd	15.0%	Ordinary	
3	Dr. Johan van der Merwe	12.0%	Ordinary	
4	Reddy Family Trust	11.0%	Ordinary	
5	Thabo Molefe	10.0%	Ordinary	
6	Sarah Botha	9.0%	Ordinary	
7	Dr. Ahmed Kara	8.0%	Preferential	
8	Naledi Zulu	7.0%	Ordinary	
9	Michael Roberts	6.0%	Ordinary	
10	Dr. Vikram Chetty	4.0%	Preferential	
Total shareholders: 10				